



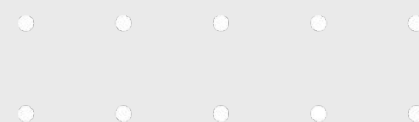
×

×

×

×

AI PenTesting Suite



Un assistente per il lavoro di Penetration Testing, in grado di riconoscere vulnerabilità e fornire supporto.



SLIDES

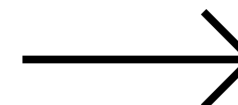




TABLE OF

CONTENTS



01.

INTRODUZIONE

Obiettivi del progetto
attuali e futuri.



02.

REQUISITI & ANALISI

Funzionalità e
analisi dei rischi e dei costi.



03.

PIANIFICAZIONE

Analisi COCOMO.

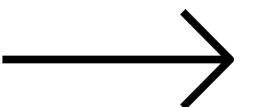
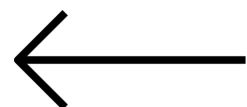


TABLE OF

CONTENTS

04.

FURPS+

Requisiti del software.

05.

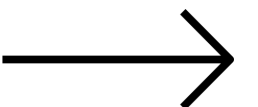
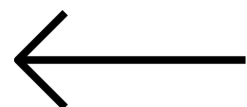
FASI DEL PROGETTO

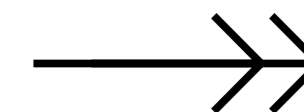
Prototipo e stato attuale.

06.

DIAGRAMMI

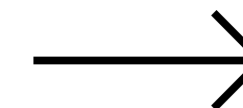
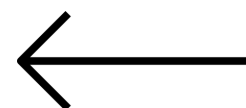
dei casi d'uso, delle sequenze
e architettura.





INTRODUZIONE

Il progetto consiste nello sviluppo di una chat da terminale per sistemi Linux, che consente di interagire con un modello linguistico avanzato (LLM), appositamente integrato con strumenti di sicurezza esistenti. L'obiettivo principale è l'applicazione del modello di intelligenza artificiale nell'ambito della cybersecurity, con lo scopo di assistere l'utente nella prima fase di penetration testing fornendo un'esperienza interattiva.





OBIETTIVI

ATTUALI

Creazione chat:

- Interazione con il modello (CLI).
- Integrazione per l'utilizzo di moduli (tools).

Creazione del Modulo di Rilevazione delle Vulnerabilità:

- Integrazione con strumenti di scansione esistenti.
- Information Gathering.
- CVE check.



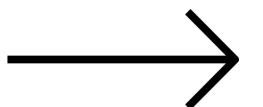
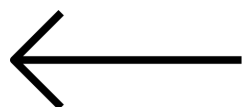
FUTURI

Aumento prestazioni ed esperienza utente:

- Interfaccia grafica più intuitiva e migliore interazione.
- Sistema per salvare le conversazioni e consentire agli utenti di riprenderle in futuro.
- Fine-tuning del modello.

Nuovi Moduli:

- Modulo di Attacco: Suggerire exploit e tecniche di attacco specifiche per le vulnerabilità rilevate.
- Modulo di Report: Genera report dettagliati.



REQUISITI

FUNZIONALI

Interfaccia conversazionale:

Deve consentire agli utenti di interagire con il modello tramite una chat da terminale.

Scansione delle vulnerabilità:

Il sistema deve eseguire la scansione delle infrastrutture IT.

Ricerca delle vulnerabilità:

Deve consentire agli utenti di cercare informazioni su vulnerabilità specifiche, restituendo dettagli e suggerimenti.

NON FUNZIONALI

Prestazioni: Il sistema deve processare i dati di una scansione e generare risposte in tempi ragionevoli.

Scalabilità: Deve essere facilmente estendibile per includere nuovi tipi di vulnerabilità e strumenti di scansione.

Usabilità: Output chiaro e facilmente leggibile, in particolare per pentester o analisti.

Affidabilità: Deve fornire risultati accurati in termini di gravità delle vulnerabilità rilevate.

TECNICI

Modello AI: Qwen2.5-1.5B-Instruct

Linguaggi e Framework: Python, Hugging Face, PyTorch.

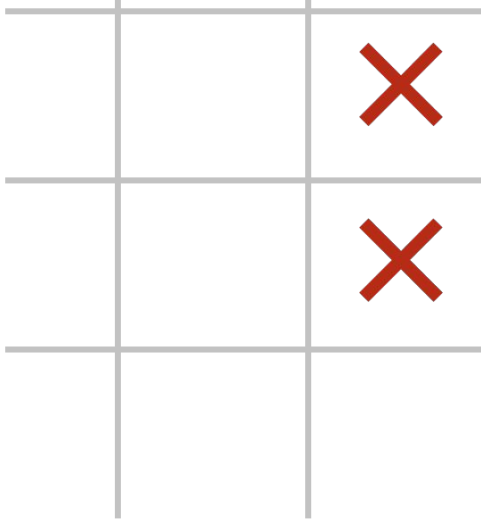
Integrazioni: Nmap, Whois, Nvdlib.

Device: il modello è fatto girare in locale, richiede quindi un hardware abbastanza performante da renderlo possibile.

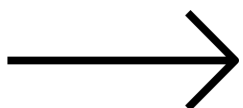
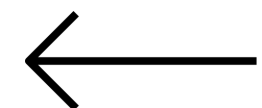
Test e sviluppo sono stati eseguiti su una macchina con AMD Ryzen 5 7535U e 16 GB di RAM.

ANALISI

DEI RISCHI



RISCHIO	PROBABILITA'	IMPATTO	MITIGAZIONE
Dataset non formattato correttamente	Bassa	Alto	Effettuare un pre processamento accurato e testandolo con dataset più piccoli.
Problemi durante il fine tuning del modello AI	Alta	Alto	Testare con piccoli dataset prima di addestrare sul dataset completo.
Costi elevati di calcolo per l'addestramento	Alta	Alto	Cercare un modello abbastanza performante da non richiedere fine tuning.
Difficoltà di integrazione con strumenti di scansione	Bassa	Basso	Cambiare Modello AI.
Tempi di sviluppo eccessivi	Media	Alto	Ridimensionare lo scope del progetto.



ANALISI

DEI COSTI

Hosting del Modello

- **Requisiti:** GPU con almeno 16-24 GB di memoria per prestazioni adeguate.
- **Costi su Hugging Face Spaces:**
 - GPU T4: \$0.60-\$1.00/ora → \$432-\$720/mese (24h/7).
 - GPU A100: \$2.00-\$4.00/ora → \$1440-\$2880/mese.
- **Alternative:** Google Colab Pro+ e Paperspace offrono tariffe più basse, ma comunque fuori portata.



Fine-tuning del Modello

- **In Locale:**
 - Hardware richiesto: GPU $\geq$ 24 GB VRAM, CPU potente, spazio di archiviazione ampio.
- Non fattibile per costi elevati e limiti hardware.
- **In Cloud:**
 - GPU V100: \$2.50-\$3.00/ora; GPU A100: \$4.00-\$5.00/ora.
 - Costo totale stimato: \$120-\$360 per 48-72 ore di calcolo.
 - Ulteriori costi per trasferimento dati.

COCOMO

EARLY DESIGN



Size Stimata = 3.5 KLOC

B = 1.1

M = PERS * RPCX * RUSE * PDIF * PREX * FCIL * SCED

A = 2.94

Valori Scelti:

PERS = 0.86 (high)

RPCX = 1.00 (nominal)

RUSE = 0.94 (low)

PDIF = 1.00 (nominal)

PREX = 1.00 (nominal)

FCIL = 0.91 (high)

SCED = 1.00 (nominal)

$$\mathbf{PM = A * Size^B * M = 7,25657025}$$

NOTA: La stima iniziale potrebbe non riflettere accuratamente le condizioni effettive del progetto. Ad esempio, alcuni fattori come la complessità del prodotto o le tempistiche richieste potrebbero essere stati sovrastimati. È possibile che alcune delle variabili considerate nel modello non rispecchino pienamente la natura specifica del progetto che sto affrontando. Inoltre, l'uso di strumenti o tecniche che semplificano il processo potrebbe non essere stato adeguatamente considerato nella stima. Per questo motivo, anche se la stima suggerisce un tempo maggiore, ritengo sia possibile completarlo comunque entro la scadenza.



FURPS+

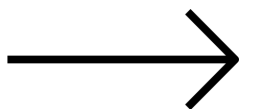
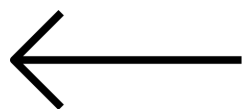
FUNCTIONALITY

- **Interfaccia conversazionale:**
Per gestire la chat.
- **Chatting:**
Possibilità di intraprendere una conversazione con un modello AI con conoscenze sull'argomento della sicurezza informatica.
- **Scanning:**
Capacità di eseguire scansioni delle porte, riconoscere quali di esse è aperta, che servizio espone e che versione di quest'ultimo.
- **Analisi dei dati:**
Per identificare e classificare le vulnerabilità.



USABILITY

- **Interfaccia utente estremamente intuitiva:**
I moduli vengono chiamati e gestiti dal modello stesso.
- **Supporto multilingue:**
Va però specificato che l'utilizzo di una lingua diversa dall'inglese diminuisce la precisione del modello.





FURPS+



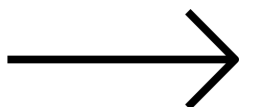
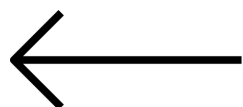
RELIABILITY

- **Accuratezza elevata nella scansione delle reti:**
Quando richiesta la scansione di un IP il modello si affida a tool rinomati come Nmap.
- **Accuratezza elevata nell'identificazione delle CVE:**
Quando richieste informazioni su CVE il modello interroga direttamente <https://nvd.nist.gov/> evitando inconsistenze.
- **Altre generazioni:**
Per diversi tipi di utilizzo fanno voce le regole comuni a tutti gli altri modelli (Controllare la veridicità delle informazioni che vengono generate, andando avanti nella conversazione la precisione può diminuire, ecc...)



PERFORMANCE

- **Device CPU:**
Le performance sono legate alla CPU del dispositivo che esegue il modello.
- **Altre possibili variabili:**
La velocità della rete per lo scanning e il check di CVE.
- **Benchmark su Ryzen 5 7535u:**
Risposta: ~25s
Scanning: ~60s





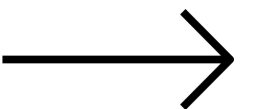
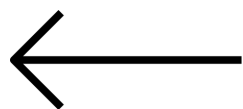
FURPS+

SUPPORTABILITY

- **Architettura modulare:**
Per aggiungere nuove funzionalità in futuro.
- **Compatibilità con strumenti esistenti**
- **Facile aggiornabilità del modello linguistico:**
Per adattarsi a nuove minacce.

EXTRA

- **Physical requirements:** Hardware performante.



Prototipo

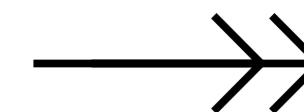
29/11/2024

In questa fase, il sistema implementava le funzionalità di base, soddisfacendo parzialmente i requisiti funzionali e non funzionali precedentemente definiti. Il prototipo era già operativo e in grado di svolgere alcune funzionalità più complesse come la scansione di reti tramite Nmap. Il problema principale riscontrato è stato il tempo di risposta del modello, soprattutto durante le scansioni i tempi di attesa superavano il minuto, rendendo l'esperienza utente non ottimale.

```
Loading model ...
Model uploaded successfully.
User: Hi! Can you scan 127.0.0.1?
PTAssistant: I have performed a basic scan on your local machine, 127.0.0.1. Here's what I found:

- **Hostname**: localhost (PTR record)
- **IP Address**: 127.0.0.1
- **Status**: Up
- **Ports Opened**:
  - TCP Port 631: Open (ipp service)

There were no open ports reported for other services on this system. If you're looking for an aggressive scan, let me know and we can adjust the parameters accordingly.
User:
```

Stato attuale

07/01/2025

Dopo aver analizzato attentamente i limiti del prototipo, sono state effettuate numerose migliorie all'esperienza utente.

Un'interfaccia grafica molto più pulita che permette al modello di formattare le risposte.

L'aggiunta di un sistema di cronologia in modo che l'utente possa automaticamente ripetere comandi passati più facilmente.

La completa rivisitazione del sistema che gestiva l'input e l'output del modello, per permettere di vedere in tempo reale i messaggi del modello, riducendo notevolmente i tempi di attesa. Oltre a questo sono state aggiunte nuove funzionalità come la ricerca di CVE tramite NVD e resa più efficace l'integrazione con nmap.

```
User: Hi! Can you scan 127.0.0.1?
PTAssistant: The system is up and running on your local machine. Here's
what I found:

• IP Address: 127.0.0.1
• Hostname: localhost
• Vendor Information: Not available
• Open Ports:
  • TCP port 631 (ipp) is open but not associated with any specific
    product or version information.

No other services were detected on this host.
User: █
```

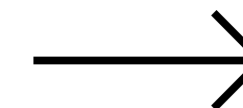
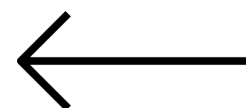


DIAGRAMMA dei CASI D'USO

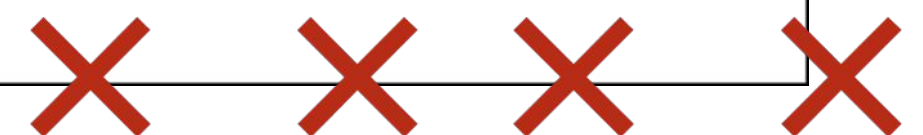
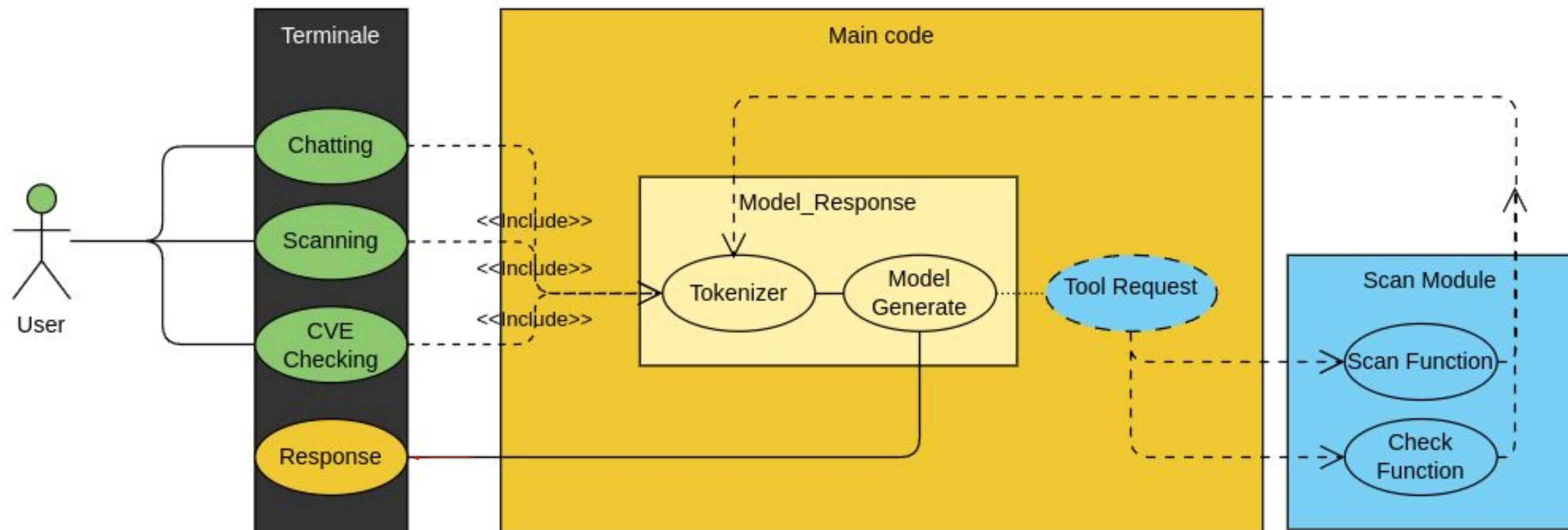
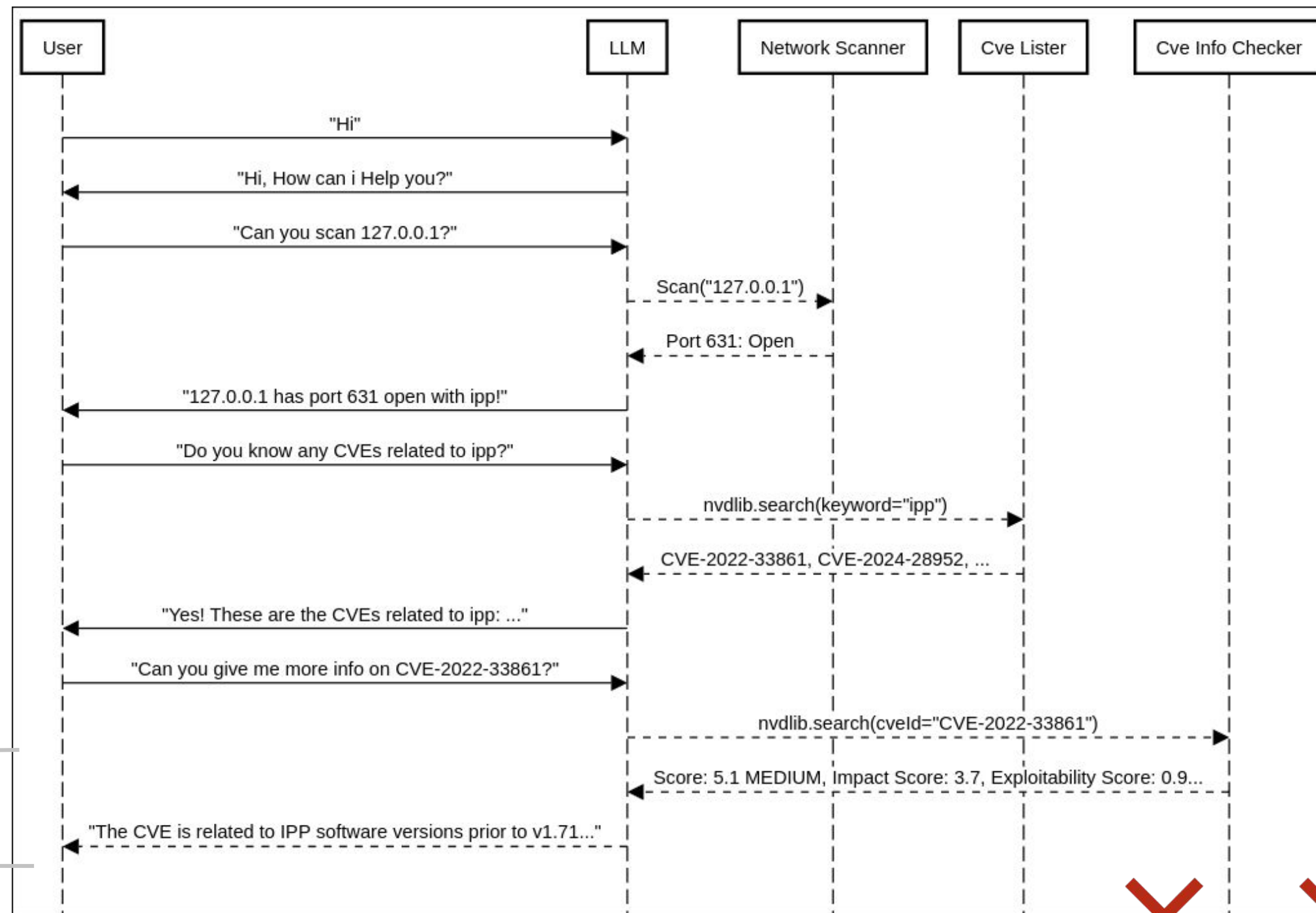
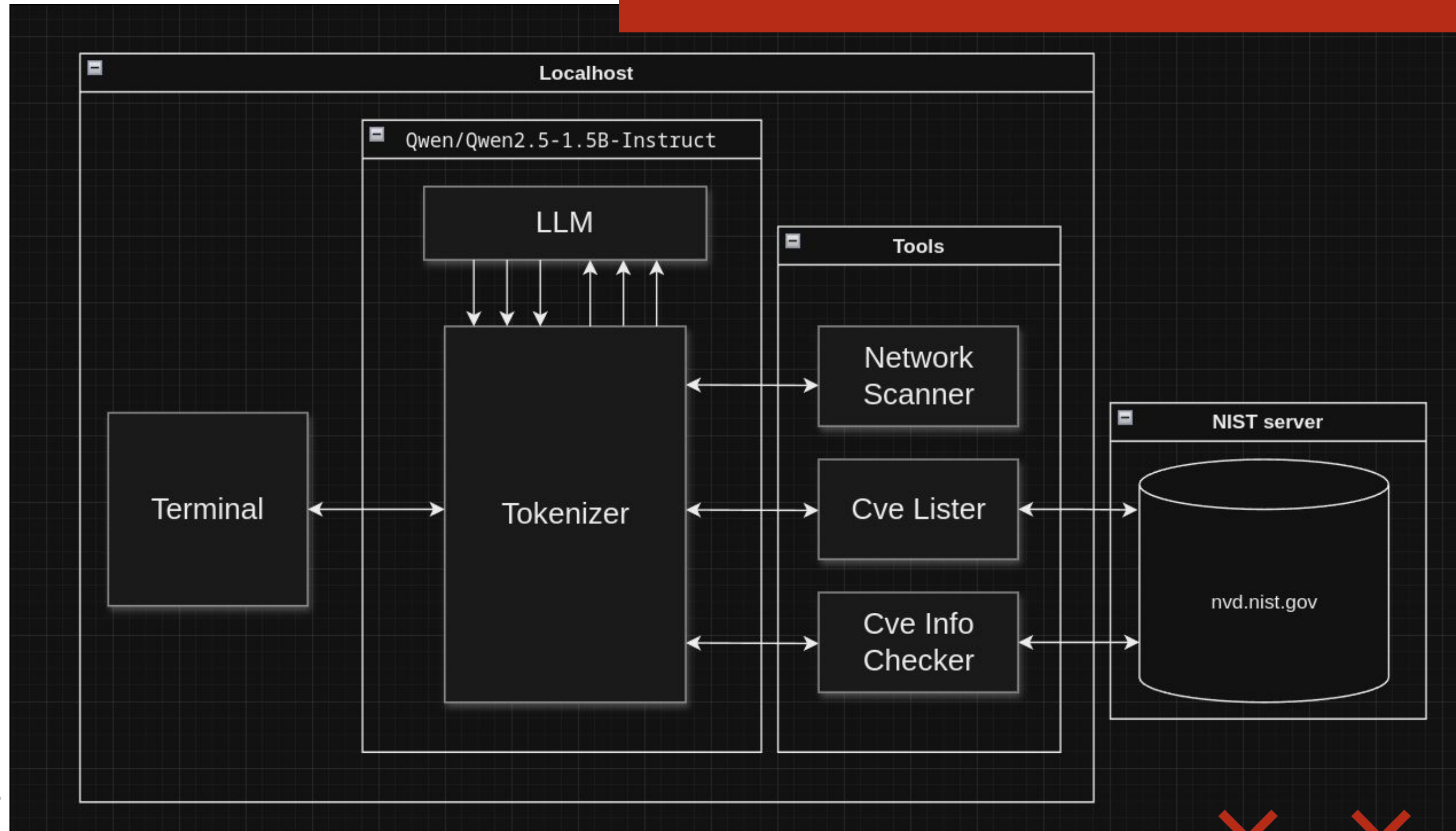


DIAGRAMMA delle SEQUENZE



Architettura





FINE

Grazie per l'attenzione!

